

Article 14 Gatekeeper

A release gate for the EU Cyber Resilience Act,
operated by IBM Bob 2.0.

24 h · early warning

72 h · notification

14 d · final report

THE PROBLEM

Since 11 September 2026, an exploited vulnerability starts a legal clock

24 h

Early warning to the CSIRT and
ENISA

72 h

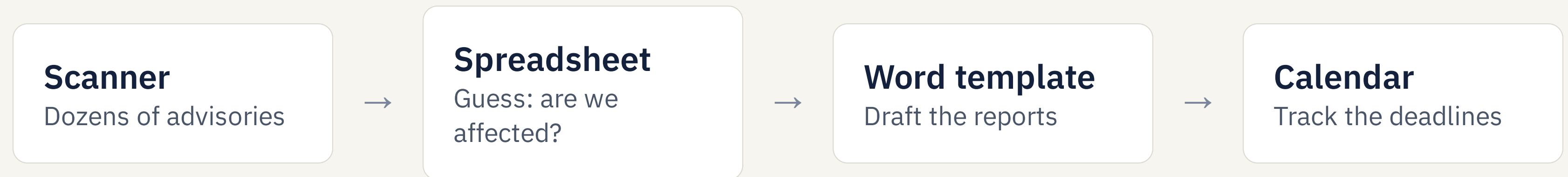
Vulnerability notification

14 d

Final report, counted from the
fix

TODAY

Compliance is a manual chore spread across four tools



On our demo product, **12 advisories** came back and only **5 touched code it actually runs**. Every one of the 12 still had to be read and judged by hand.

THE GATE

A deterministic core turns evidence into **PASS** or **BLOCK**

01

SBOM

CycloneDX 1.5 of
every pinned
component

02

Advisories

OSV.dev, GHSA and
PYSEC merged by
CVE

03

Reachability

file:line proof the
vulnerable call runs

04

OpenVEX

every "not affected"
carries a reason

05

Art. 14

clocks and drafts
from the regulation's
fields

One exit code, so it runs in CI, in git hooks and inside the IDE.

IBM BOB 2.0 IS THE OPERATOR

In CRA Release Officer mode, Bob runs three subagents in parallel

Remediation

Upgrades PyYAML and requests, swaps in safe_load, bumps to 1.4.1, runs the tests

Advisory analyst

Maps unmapped advisories to symbols and writes a reviewed VEX justification

Art. 14 drafter

Completes the early warning and the notification from Art. 14(2)

RESULT ON THE DEMO PRODUCT

From BLOCK to PASS in about 5 minutes

Gate verdict

BLOCK → **PASS**

Affected advisories

5 → **0**

Advisories on the SBOM

12 → **6**

CVE-2020-14343 (CRITICAL, reachable at config.py:8) and CVE-2018-18074 (HIGH) fixed; both Art. 14 drafts completed; deadlines computed to the minute; the 14-day final-report clock started at the fix.

Bob cannot ship a non-compliant release, even when told to

LAYER 1 • MODE RULES

Asked to tag while the gate said BLOCK, Bob ran the gate first and refused.

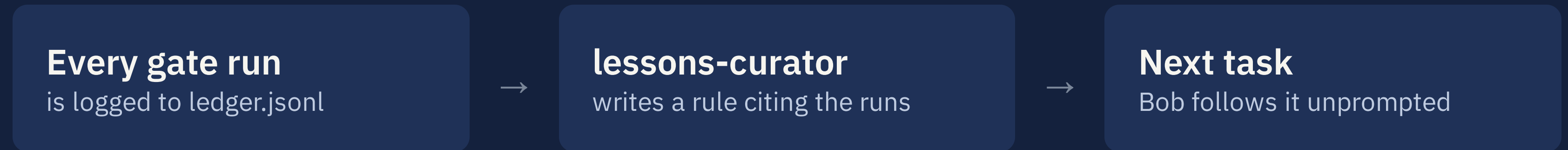
LAYER 2 • PRETOOLUSE HOOK

Told to try anyway, the hook blocked **git tag** with the CVE list. No tag was created.

```
CRA release gate: BLOCK — CVE-2020-14343 in pyyaml 5.3.1: affected (CRITICAL)
```

SELF-IMPROVING

The Lessons Ledger turns past failures into Bob rules



Asked for a new YAML-import endpoint with no security hints, Bob used **yaml.safe_load** and cited the lesson from CVE-2020-14343.

Eleven Bob tasks, each with evidence

Bob feature	What it did
Document understanding	Read the CRA PDF, mapped Arts. 13, 14, 16 to the gate (T01)
Custom mode	cra-release-officer with its own rules (T02)
Skills	advisory-analyst, art14-drafter, cra-evidence-pack, lessons-curator (T03, T07)
Hooks	Block git push and git tag on BLOCK; log every task (T04, T04b)
Parallel subagents	Remediation, triage and drafting at once (T05, T05c)
Bug hunt	Found and fixed a draft-overwrite bug, with a test (T05b)
CI and headless	Evidence artifact, PR comment, optional Bob Shell job (T06)

WHO IT IS FOR

Every manufacturer shipping software into the EU

Less noise

Reviewers read only what the code reaches; the rest gets a signed VEX reason.

No missed clocks

Deadlines are computed and block the release, not kept in a calendar.

Audit-ready

SBOM, VEX, drafts and the ledger form the evidence pack.

Limits: Python/pip only today; static reachability; drafts are for a responsible person to submit, not legal advice.

Ship fixes, not fines.

Article 14 Gatekeeper — a CRA release gate operated by IBM Bob 2.0.

github.com/dabiH2/ibm-bob-2-hackathon · MIT

Dabii Systems · Gabriele Desimini